

Software Production Bible

Aesthetic Consultation, Clinical Photography & AI Visualization Platform

Version 1.0

Prepared for Claude-assisted production development

September 25, 2026

Purpose: This document is the authoritative product, workflow, architecture, security, acceptance, and AI-development specification for the first production build. Claude must treat it as the source of truth rather than improvising product behavior.

0. Document Control & Authority

This Production Bible defines what is being built, how major objects behave, how access is controlled, what Claude may and may not invent, and how each implementation phase is accepted. It is designed to be readable by a human engineering team and by a coding model.

Item	Specification
Document status	Approved baseline for architecture and Layer 0 / Layer 1 implementation
Product name	Working name: Aesthetic Platform. Branding may change without changing architecture.
Primary clients	Provider iOS/iPadOS app; Patient iOS app; Administrative web portal
Backend	Versioned application API, PostgreSQL, secure media storage, AI services, integrations
Authority order	Production Bible > Architecture Decisions > Database Schema > API Contracts > Security Requirements > Design System > active phase prompt
Change control	Any change to a locked workflow, state machine, permission, or data contract must be documented before implementation.

0.1 Rules Claude must follow

- Do not copy TouchMD or any other vendor's proprietary source code, trade dress, copyrighted education content, graphics, private APIs, or screen designs.
- Equivalent workflow categories are allowed, but the implementation and design language must be original.
- Do not build a mock application that bypasses authorization, persistence, audit logging, validation, or error behavior.
- Do not silently invent product behavior when this Bible already specifies it.
- When behavior is genuinely undefined and would create a permanent architectural dependency, record it as an unresolved decision instead of burying an assumption in code.
- Implement only the currently authorized phase. Finish its tests and acceptance review, then stop.

0.2 Mandatory per-feature specification

EVERY FEATURE MUST ANSWER:

1. What does it do?
2. Who may use it?
3. What data does it read or change?
4. What states may it enter?
5. How do we prove it works?

1. Product Vision, Boundaries & Success Criteria

The platform is a visual consultation and patient-engagement system for aesthetic medicine practices. It unifies patient records, standardized clinical photography, consultation workflows, education, treatment planning, consents, before/after comparison, secure communication, telehealth, and clinician-controlled AI aesthetic visualizations.

1.1 Product goals

- Give providers one consultation workspace from intake through follow-up.
- Standardize clinical photography so before/after comparisons are more consistent and reproducible.
- Provide clinician-controlled visual simulations without representing them as guaranteed outcomes.
- Keep patients engaged through a dedicated patient application containing only released materials.
- Create traceable, versioned consent and media-permission workflows.
- Support future EMR connectivity without coupling the product to one vendor.
- Create a commercial SaaS architecture that can grow from a small pilot to thousands of practices.

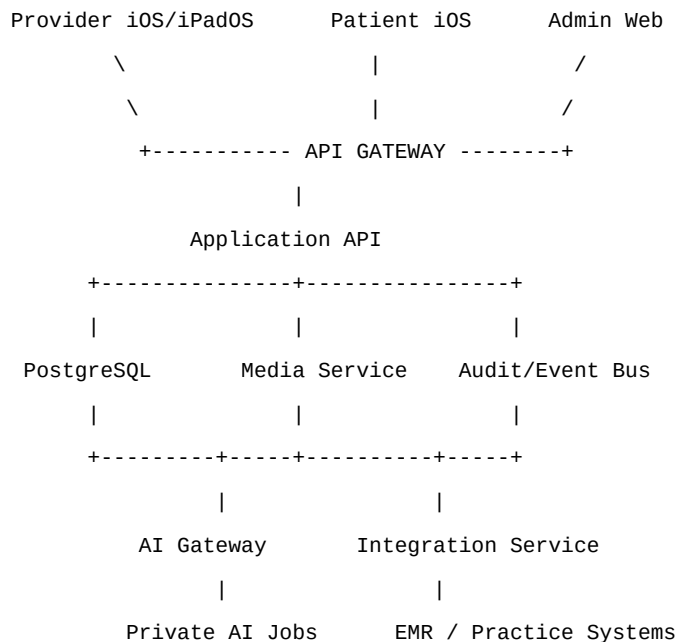
1.2 Explicit non-goals for initial production

- The AI system will not automatically diagnose conditions.
- It will not independently prescribe medication, product, dosage, injection depth, or surgical technique.
- It will not present a visualization as an exact prediction or guaranteed result.
- The MVP will not attempt to replace a full billing, claims, e-prescribing, or enterprise EHR system.
- Cross-practice patient data sharing is prohibited unless a later approved feature defines authorization and consent.
- 3D digital-patient modeling is deferred unless separately authorized.

2. Product Topology & Application Surfaces

Surface	Primary users	Responsibility
Provider iOS/iPadOS	Providers, nurses, injectors, photographers, consultants, front desk	Patient care workflow, capture, consultation, planning, consent management, secure communication
Patient iOS	Patients	View released consultations, simulations, documents, instructions, appointments, messages, telehealth
Admin Web	Organization and practice administrators; platform operations	Users, roles, practices, locations, content, integrations, audit, configuration, support
Application API	All first-party clients	Authentication, authorization, domain logic, versioned contracts, audit
Media Service	Provider/patient/admin via API	Upload, derivatives, signed access, retention, checksum, storage isolation
AI Platform	Provider workflow through internal API	Quality checks, landmarks, segmentation, simulation, validation, provenance
Integration Service	Backend only	FHIR/HL7/vendor adapters, sync status, mapping, retries

2.1 High-level architecture



3. Tenancy, Identity, Roles & Permissions

3.1 Tenant hierarchy

PLATFORM

-> ORGANIZATION

-> PRACTICE

-> LOCATION

Every tenant-owned record must carry organization ownership. Practice/location scoping is added where operationally relevant. Server-side authorization determines access; organization identifiers supplied by clients are never proof of entitlement.

3.2 Core roles

Role	Typical scope
SUPER_ADMIN	Platform operations only; tightly restricted and audited
ORGANIZATION_ADMIN	Organization configuration, users, practices, audit
PRACTICE_ADMIN	Practice operations, staff, content/configuration within assigned scope
SURGEON / PHYSICIAN	Clinical consultation, photos, treatment plans, AI review/approval
NURSE / INJECTOR / AESTHETICIAN	Assigned clinical workflows according to permissions
PHOTOGRAPHER	Photo capture and permitted image workflows
CONSULTANT	Consultation/treatment-plan workflow without implicit clinical authority
FRONT_DESK	Scheduling and approved demographic workflows
MARKETING	Only media explicitly granted for approved marketing use
PATIENT	Own released patient-facing records only

3.3 Permission model

```

patient.read      patient.create      patient.update      patient.archive
photo.capture     photo.view           photo.annotate      photo.export
photo.permission.read / manage
consultation.create consultation.edit      consultation.complete
simulation.create  simulation.generate  simulation.review    simulation.approve
simulation.release
treatmentplan.create / edit / send
consent.template.manage consent.assign consent.sign.provider consent.void
message.send      appointment.manage  telehealth.start
user.read / create / update / disable
role.read / assign
practice.read / manage
content.read / manage
integration.read / manage
audit.read

```

Roles grant permissions. API services evaluate permissions. UI hiding is convenience only and is never a security boundary.

4. Patient Record & Intake

4.1 Patient creation workflow

```

Authenticated staff
-> New Patient
-> Enter demographics
-> Validate fields
-> Search for probable duplicates
-> Confirm creation
-> Server assigns tenant ownership
-> Create record
-> Write PATIENT_CREATED
-> Open patient profile

```

4.2 Minimum patient entity

Field	Notes
id	UUID
organizationId	Server-controlled tenant ownership
primaryPracticeId	Optional/required by deployment policy
firstName / middleName / lastName / preferredName	Demographics
dateOfBirth	Date only
email / phone	Validated when supplied
MRN	Internal or externally mapped identifier
externalEMRIdentifier	Optional
status	ACTIVE, INACTIVE, ARCHIVED, DECEASED where policy supports
createdAt / updatedAt	Timestamps
createdBy / updatedBy	Actor references

4.3 Patient profile

- Overview
- Timeline
- Consultations
- Photos
- Before / After
- AI Simulations
- Treatment Plans
- Procedures
- Documents
- Instructions
- Appointments
- Messages

Opening a patient requires authentication, tenant scope validation, patient.read permission, and a PATIENT_VIEWED audit event.

5. Consultation Workflow

5.1 Mandatory sequence

Open Patient

- > Create Consultation
- > Select reason / concerns
- > Review relevant history
- > Select photography protocol
- > Capture/import permitted photos
- > Photo quality review
- > Annotate if needed
- > Present assigned education
- > Discuss procedures
- > Optional AI visualization
- > Provider reviews simulation
- > Create treatment plan option(s)
- > Create estimate
- > Assign consent(s)
- > Assign instructions
- > Schedule/propose next step
- > Generate consultation summary
- > Release approved patient-facing materials
- > Complete consultation
- > Audit lifecycle events

5.2 Consultation state machine

DRAFT

- > IN_PROGRESS
- > AWAITING_INFORMATION
- > READY_FOR_REVIEW
- > COMPLETED
- > ARCHIVED

Any non-final state may become CANCELLED when allowed by policy.

Invalid transitions are rejected server-side.

6. Clinical Photography

6.1 Photo session ownership

PhotoSession belongs to an organization, patient, photography protocol, capturing user, date/time, and optional consultation/procedure/location.

6.2 Standard protocol examples

Protocol	Views
Face	Front; Left 45; Right 45; Left profile; Right profile
Breast	Front; Left oblique; Right oblique; Left lateral; Right lateral
Abdomen/body contour	Front; Left 45; Right 45; Left profile; Right profile; Back

Practices may author custom protocols. Each protocol marks views as required or optional and can define capture instructions.

6.3 Capture workflow

```

Choose patient + protocol
-> Choose required view
-> Open camera
-> Evaluate orientation / pose / framing / distance / tilt / lighting
-> Show live correction guidance
-> Capture
-> Post-capture quality checks
-> Accept or retake
-> Encrypt/upload immutable original
-> Generate derivatives
-> Record metadata + checksum
-> PHOTO_CAPTURED
-> Next view

```

6.4 Live guidance vocabulary

- MOVE LEFT / RIGHT
- MOVE CLOSER / BACK
- CAMERA TOO HIGH / LOW
- LEVEL CAMERA
- PATIENT TURN LEFT / RIGHT
- RAISE / LOWER CHIN
- LIGHTING TOO DARK
- RETAKE - MOTION BLUR

6.5 Ghost alignment

A previous standardized image may be overlaid on the live camera with adjustable opacity. Landmark/pose comparison may produce a photographic position-match score and guidance. It must not be labeled medical accuracy.

6.6 Original image protection

ORIGINAL (immutable)

- | - THUMBNAIL
- | - DISPLAY_PREVIEW
- | - ANNOTATION_LAYER / ANNOTATED_DERIVATIVE
- | - BEFORE_AFTER_DERIVATIVE
- | - AI_SIMULATION_DERIVATIVE
- | - MARKETING_DERIVATIVE
- ` - EXPORT_DERIVATIVE

Original assets are never destructively edited. Every derivative references its source and generation metadata.

7. Media Permissions & Releases

7.1 Independent permission categories

- CLINICAL_USE
- PATIENT_APP
- EDUCATION
- WEBSITE
- SOCIAL_MEDIA
- PAID_ADVERTISING
- RESEARCH
- AI_TRAINING
- INTERNAL_AI_EVALUATION

7.2 Permission states

NOT_REQUESTED -> REQUESTED -> GRANTED or DECLINED

GRANTED -> REVOKED or EXPIRED

No permission implies another. Clinical use does not imply website, advertising, research, or AI training. Each change is versioned and audited.

7.3 Enforcement

- Marketing export checks current permission at time of export.
- Patient-app visibility checks PATIENT_APP permission plus provider release state.
- AI-training pipelines may ingest only assets with explicit AI_TRAINING permission and applicable governance approval.
- Revocation prevents future use in the affected purpose and triggers any defined downstream compliance workflow.

8. Before / After Comparison

8.1 Creation

Select patient

- > Choose before
- > Choose after
- > Backend verifies same patient + authorization
- > Verify matching/compatible view
- > Optional automatic registration
- > Manual alignment if needed
- > Save BeforeAfterSet

8.2 Comparison modes

- Side-by-side
- Swipe slider
- Cross-fade
- Blink
- Overlay
- Synchronized zoom
- Synchronized pan
- Reset / registration controls

8.3 Export

Export requires authorization and purpose-specific permission. Export creates a derivative and PHOTO_EXPORTED audit event. Original clinical media remains unchanged.

9. AI Aesthetic Outcome Simulation

Product language: simulation or visualization, not guaranteed result, exact prediction, or outcome probability.

9.1 Patient-facing disclaimer

AI-generated visualization for consultation purposes. Actual clinical outcomes vary. This visualization is not a guarantee or prediction of medical results.

9.2 Simulation pipeline

```
Source image(s)
-> Input quality validation
-> Landmark detection
-> Treatment-region segmentation
-> Identity representation
-> Provider-defined visualization parameters
-> Constrained transformation
-> Outside-region identity similarity check
-> Artifact detection
-> Output validation
-> READY_FOR_PROVIDER_REVIEW
-> Provider approve / reject / regenerate
-> Explicit release to patient
```

9.3 State machine

```
DRAFT
-> QUEUED
-> PROCESSING
-> VALIDATING
-> READY_FOR_PROVIDER_REVIEW
-> APPROVED | REJECTED | REGENERATING | FAILED
APPROVED -> RELEASED_TO_PATIENT
Any retained terminal result -> ARCHIVED when allowed
```

9.4 Provenance

- source asset IDs
- procedure/treatment region
- AI model ID and version
- inference configuration and provider-set parameters
- mask/segmentation reference when retained
- output asset ID
- timestamps
- generating user
- reviewing provider

- approval and release events

9.5 Identity-preservation rules

The system must minimize unintended changes outside the treatment region. A lip visualization must not unnecessarily alter eyes, nose, ears, hair, unrelated skin, background, or overall identity. Outputs crossing configured artifact/similarity thresholds are rejected or flagged before release.

9.6 Initial visualization categories

Category	Provider controls / restrictions
Lip filler	Upper/lower visual volume, projection, Cupid's bow/vermillion definition; no dosage
Rhinoplasty	Bridge/dorsal contour, tip projection/rotation, width; no surgical-technique recommendation
Botulinum-toxin aesthetic visualization	Region-based appearance visualization; no brand, drug, units, depth, needle, or injection plan
Cheek/chin/jaw filler	Visual contour/intensity only; no product or dosing
Facelift/neck lift/blepharoplasty/brow lift	Visualization parameters defined per validated model; no guarantee
Breast/body contour procedures	Multi-view visualization when validated; no operative-plan automation
Skin resurfacing/tightening	Appearance visualization only within validated domain

9.7 Model registry

Every production model has immutable model/version records, validation metadata, activation status, and rollback capability. A production model is never silently replaced.

10. Similar Historical Cases & Outcome Library

A provider may search the practice's appropriately consented, de-identified or otherwise authorized historical case library for visually relevant examples. Results are labeled Similar Historical Cases, never Your Predicted Result.

- Strict tenant boundaries.
- Only media with the required consent/permission may enter the library.
- Search may use procedure, view, starting visual features, and approved metadata.
- The system records which historical cases were shown during a consultation.
- Cross-organization datasets require a separately approved governance model.

11. Treatment Plans, Estimates & Procedure Tracking

11.1 Treatment plan composition

- Procedure / treatment
- Area
- Provider
- Description
- Quantity where appropriate
- Price
- Discount
- Estimated total
- Financing reference
- Notes
- Proposed date

A consultation may present Plan A, Plan B, and Plan C. Acceptance does not itself constitute medical authorization or consent.

11.2 State machine

DRAFT -> PROPOSED -> SENT_TO_PATIENT -> VIEWED -> ACCEPTED | DECLINED | EXPIRED

ACCEPTED -> SCHEDULED -> COMPLETED | CANCELLED

11.3 Pricing boundary

The platform can produce estimates and references to financing/payment systems, but the initial architecture does not assume a full accounting ledger, claims platform, or payment processor. Those capabilities require a separately approved billing scope.

12. Documents, Consents, Instructions & Education

12.1 Consent builder

- Heading
- Paragraph
- Bullets
- Image
- Video acknowledgment
- Checkbox
- Required checkbox
- Initial
- Text field
- Date
- Patient signature
- Provider signature
- Witness signature

12.2 Consent versioning

Publishing a new template creates a new version. Previously executed documents never change when a template is edited.

12.3 Consent workflow

```
Create template -> Publish version -> Assign
-> Patient views -> Required acknowledgments
-> Patient signature -> Provider/witness signatures if required
-> Create immutable signed snapshot
-> Generate document hash
-> COMPLETE
```

12.4 Consent states

```
DRAFT -> ASSIGNED -> VIEWED -> IN_PROGRESS -> SIGNED_BY_PATIENT -> SIGNED_BY_PROVIDER -> COMPLETE
COMPLETE may later be VOIDED or SUPERSEDED according to policy.
```

12.5 Education CMS

Content types include video, image, animation, text, PDF, procedure explanation, FAQ, pre-op instruction, and post-op instruction. Track assigned/opened/viewed/completed/acknowledged state where appropriate.

12.6 Instructions

Instructions are versioned and assigned by procedure or consultation. Patient acknowledgment is tracked separately from clinical completion.

13. Patient iOS Application

13.1 Navigation

- Home
- My Consultation
- My Simulations
- My Photos
- My Treatment Plans
- My Procedures
- My Documents
- My Instructions
- Appointments
- Messages
- Telehealth
- Profile

13.2 Visibility rule

The patient can view only records belonging to that patient and only content explicitly released/assigned to the patient surface. Provider drafts and rejected simulations are never exposed.

13.3 Patient actions

- View released consultation summaries and education.
- View provider-released simulations.
- Upload requested photos into a controlled intake workflow.
- Review/sign assigned consent documents.
- Acknowledge assigned instructions.
- View/propose appointments where enabled.
- Send/receive secure messages.
- Join scheduled telehealth sessions.
- Manage account/session/security preferences.

13.4 Patient-photo upload workflow

Provider requests photo(s)

-> Patient sees protocol/instructions

-> Capture/upload

-> Client quality guidance where available

-> Upload to quarantine/intake state

-> Malware/file validation

-> Provider/staff review

-> Accept into clinical record or request retake

-> Audit events

14. Secure Messaging & Notifications

14.1 Messaging

MessageThread belongs to organization and patient. Access requires thread membership plus applicable permission. Messages support text, approved images, documents, and instruction references.

14.2 Message states

DRAFT -> SENT -> DELIVERED -> READ

SENT may become FAILED with retry metadata.

14.3 Push notifications

Push payloads must not contain sensitive patient/clinical content. Use generic text such as 'You have a new secure message.'

14.4 Attachment controls

- Authorized file types and size limits
- Malware/content scanning where appropriate
- Signed short-lived download access
- No permanent public URLs
- Audit download/view events where required

15. Appointments & Scheduling

15.1 Appointment fields

- patient
- practice/location
- provider
- appointment type
- start/end
- timezone
- status
- reason
- linked consultation/procedure
- source system
- external identifier

15.2 Appointment states

REQUESTED -> CONFIRMED -> CHECKED_IN -> IN_PROGRESS -> COMPLETED

REQUESTED/CONFIRMED -> CANCELLED

CONFIRMED -> NO_SHOW

15.3 Integration behavior

If an external system is system-of-record, local appointments carry mapping and sync metadata. Conflicts are surfaced; they are not silently overwritten.

16. Telehealth

16.1 Capabilities

- Waiting room
- Video/audio
- Mute
- Camera switch
- Optional screen/photo sharing
- Consultation context
- Treatment-plan review
- Call metadata

16.2 Recording

Calls are not recorded by default. Any future recording capability requires a separate consent, retention, encryption, and jurisdiction review.

16.3 Telehealth states

SCHEDULED -> WAITING -> ACTIVE -> ENDED

Any pre-active state may become CANCELLED

ACTIVE may become DISCONNECTED and reconnect when supported.

17. Administrative Web Portal

17.1 Modules

- Organizations / practices / locations
- Users, roles, permission assignments
- Provider profiles
- Photography protocols
- Content library
- Consent templates and versions
- Treatment/procedure catalog
- AI model registry visibility and rollout controls
- Integrations and mapping status
- Audit viewer
- Security/session/device administration
- Feature flags and practice configuration
- Support tooling with tightly controlled impersonation/break-glass if ever implemented

17.2 Administrative safeguards

Sensitive support access must be minimal, explicit, time-bound where possible, and audited. Platform operators must not have casual browsing access to patient records.

18. EMR / Practice-System Integration Layer

18.1 Adapter boundary

IntegrationService

-> IntegrationAdapter interface

-> FHIR Adapter

-> Vendor A Adapter

-> Vendor B Adapter

-> CSV/SFTP import adapter (only if approved)

Vendor-specific mapping must stay inside adapters, not leak throughout product code.

18.2 Canonical resources

- Patient
- Practitioner
- Appointment
- Encounter
- DocumentReference
- Media
- Consent
- Procedure
- Observation where genuinely needed

18.3 Sync states

PENDING -> RUNNING -> SUCCEEDED | PARTIAL | FAILED -> RETRY_SCHEDULED

18.4 Integration requirements

- External ID mapping
- Idempotent upserts where possible
- Conflict detection
- Retry/backoff
- Dead-letter handling
- Per-sync audit/status
- No silent data loss
- Field-level provenance for mapped data where practical

19. Canonical Data Model

The initial relational model should include at minimum the following entities. Exact table names may vary, but semantics must remain explicit.

Domain	Entities
Identity & tenancy	User, Organization, Practice, Location, Membership, Role, Permission, RolePermission, UserRole, Device, Session
Provider & patient	ProviderProfile, StaffProfile, Patient, PatientContact, PatientMedicalHistory, PatientConcern
Scheduling & consultation	Appointment, Consultation, ConsultationNote, Procedure, Treatment, TreatmentCategory, TreatmentPlan, TreatmentPlanItem
Photography	PhotographyProtocol, PhotographyProtocolView, PhotoSession, PatientPhoto, PhotoDerivative, PhotoAnnotation, PhotoTag, PhotoPermission, MediaRelease, BeforeAfterSet
AI	Simulation, SimulationVersion, SimulationParameter, SimulationApproval, AIJob, AIModel, AIModelVersion, AIValidationRecord, SimilarCaseMatch, OutcomeMeasurement
Documents	ConsentTemplate, ConsentTemplateVersion, ConsentAssignment, ConsentSignature, Document, DocumentVersion, PatientInstruction, EducationContent, ContentAssignment
Communication	MessageThread, ThreadParticipant, Message, MessageAttachment, Notification, TelehealthSession
Integration & audit	Integration, IntegrationMapping, EMRSyncEvent, AuditEvent, LoginEvent
Commercial/config	Estimate, Quote, InvoiceReference, FeatureFlag, PracticeSetting

19.1 Global data rules

- Use UUIDs for externally exposed primary identifiers.
- Tenant-owned records include organizationId.
- Use foreign keys and indexes.
- Use soft deletion only where retention/history requires it; do not use soft deletion as a substitute for access control.
- Use JSON only for intentionally flexible metadata, not for core relational concepts.
- Track createdAt/updatedAt and authorship where clinically/operationally meaningful.
- Critical lifecycle objects use explicit status enums/state machines rather than clusters of booleans.

20. API Contract & Service Conventions

20.1 Namespace

/api/v1/...

20.2 Resource map

/auth
 /organizations
 /practices
 /locations
 /users
 /roles
 /permissions
 /patients
 /patients/:id/consultations
 /patients/:id/photo-sessions
 /patients/:id/photos
 /patients/:id/before-after
 /patients/:id/simulations
 /patients/:id/treatment-plans
 /patients/:id/documents
 /patients/:id/appointments
 /patients/:id/message-threads
 /consent-templates
 /content
 /telehealth
 /integrations
 /audit

20.3 Contract rules

- DTOs are separate from database models.
- Consistent pagination, filtering, sorting, and validation errors.
- Server-generated correlation/request ID.
- Idempotency keys for retry-sensitive mutations such as uploads, signatures, AI job creation, and external sync.
- ETag/version/conflict strategy for concurrently editable records.
- Short-lived signed upload/download URLs for media where architecture supports them.
- Rate limits and abuse controls appropriate to endpoint sensitivity.
- No patient enumeration through error-message differences.

20.4 Error envelope

```

{
  "error": {
    "code": "PATIENT_NOT_FOUND",

```

```
    "message": "The requested patient could not be accessed.",  
    "requestId": "..."  
  }  
}
```

Messages must be useful without exposing internal stack traces, SQL, storage keys, or sensitive cross-tenant existence information.

21. Authentication, Security & Privacy Architecture

21.1 Authentication

- OIDC/OAuth-compatible identity architecture.
- Short-lived access tokens and controlled refresh/session lifecycle.
- Server-side session/device revocation.
- Provider-app Face ID / Touch ID reauthentication using LocalAuthentication where appropriate.
- Secrets stored in Keychain on iOS.
- Administrative MFA support/requirement according to deployment policy.

21.2 Security rules

- TLS in transit.
- Encryption at rest for database, object storage, backups, and applicable local cache.
- KMS-managed keys/envelope encryption where appropriate.
- No sensitive data in application logs, analytics, crash payloads, or push notifications.
- No public object buckets or permanent public patient-media URLs.
- Tenant isolation enforced in application/service layer and tested automatically.
- Signed temporary media access.
- WAF/rate limits/abuse monitoring for public endpoints.
- Secrets Manager or equivalent for backend secrets.
- Least-privilege IAM and service-to-service authentication.
- Immutable/tamper-resistant audit strategy appropriate to deployment.
- Dependency and container vulnerability scanning in CI.

21.3 HIPAA-ready posture

The technical design should support healthcare privacy/security obligations when deployed for covered workflows, but legal compliance depends on the customer's role, contracts/BAA's, policies, training, incident response, retention, and configured services. The software specification therefore requires compliance-ready controls without claiming that code alone makes an organization compliant.

21.4 AI/regulatory boundary

Patient-specific aesthetic visualizations and any future clinical decision-support features require intended-use and regulatory review before claims expand. Initial AI is clinician-controlled visualization with provider review and no automatic dosing, diagnosis, treatment recommendation, or guaranteed-outcome language.

22. Audit, Retention, Export & Data Lifecycle

22.1 Minimum audit events

- LOGIN_SUCCESS / LOGIN_FAILURE / LOGOUT
- PATIENT_CREATED / VIEWED / UPDATED / ARCHIVED
- PHOTO_CAPTURED / VIEWED / EXPORTED / PERMISSION_CHANGED
- CONSULTATION_CREATED / COMPLETED
- SIMULATION_GENERATED / VIEWED / APPROVED / REJECTED / REGENERATED / RELEASED
- CONSENT_ASSIGNED / VIEWED / SIGNED / COMPLETED / VOIDED
- MESSAGE_SENT / ATTACHMENT_DOWNLOADED
- USER_CREATED / UPDATED / DISABLED / ROLE_ASSIGNED
- INTEGRATION_SYNC_STARTED / SUCCEEDED / FAILED
- DATA_EXPORT_REQUESTED / COMPLETED
- SECURITY_SESSION_REVOKED

22.2 Audit event contents

Actor, organization, resource type, resource ID, action, timestamp, request/correlation ID, and appropriate device/session metadata. Avoid embedding clinical content itself in audit metadata.

22.3 Retention

Retention periods must be policy-driven and configurable by deployment/customer requirements. Deletion/archive workflows must respect legal/clinical retention obligations, backups, and downstream integrations. Claude must not hard-code one universal retention period.

22.4 Patient export

A controlled export service may assemble authorized records, documents, and media. Export generation and download are audited. Large exports use asynchronous server jobs but the UI must expose job status; no hidden background work.

23. Offline Mode, Local Storage & Synchronization

23.1 Allowed offline

- View explicitly cached recent patients according to policy
- Capture new clinical photographs
- Draft notes/consultation content
- Annotate locally cached photos
- Queue uploads/mutations

23.2 Not available offline

- Server AI generation
- EMR sync
- Operations requiring real-time authorization confirmation
- Finalization steps configured as server-dependent

23.3 Sync rules

- All cached sensitive data encrypted.
- Queue operations with deterministic IDs/idempotency.
- Retry safely without duplicate signatures, records, or AI jobs.
- Detect edit conflicts and surface them explicitly.
- Do not silently choose the newest timestamp when doing so may discard clinical/consent information.
- Local media is purged according to cache policy after successful secure upload and verification.

24. Design System & iOS Architecture

24.1 Design principles

- Original premium clinical aesthetic
- Photography-forward
- Clean and restrained
- High information clarity
- Optimized for iPad landscape while supporting iPhone
- Accessible by default
- Consistent loading/empty/error/permission/offline states

24.2 Shared design components

- Typography
- Spacing tokens
- Buttons
- Cards
- Forms
- Search
- Tables/lists
- Navigation
- Image viewer
- Photo capture overlays
- Before/after viewer
- Simulation viewer
- Modals
- Alerts
- Status badges
- Empty/error/loading states

24.3 iOS technology

Swift 6+

SwiftUI

Swift Concurrency (async/await)

AVFoundation

Vision

CoreML where appropriate

Metal where advantageous

ARKit for future 3D

CryptoKit

LocalAuthentication

Keychain

URLSession

BackgroundTasks

Swift Package Manager

24.4 Provider modules

AppShell
Authentication
CoreNetworking
CoreSecurity
DesignSystem
PatientDomain
ConsultationDomain
Photography
Media
Annotations
BeforeAfter
Simulation
TreatmentPlans
DocumentsConsent
Education
Appointments
Messaging
Telehealth
Settings
AuditSupport

24.5 Navigation

Provider iPad uses sidebar/split-view navigation. iPhone uses an adaptive navigation stack/tab strategy. Deep links must re-run authorization and not trust cached UI state.

25. Backend & Infrastructure Architecture

25.1 Preferred stack

Backend: TypeScript + Node.js + NestJS (or another approved strongly typed framework)

Database: PostgreSQL

ORM: Prisma (or approved equivalent)

IaC: Terraform

Containers: Docker

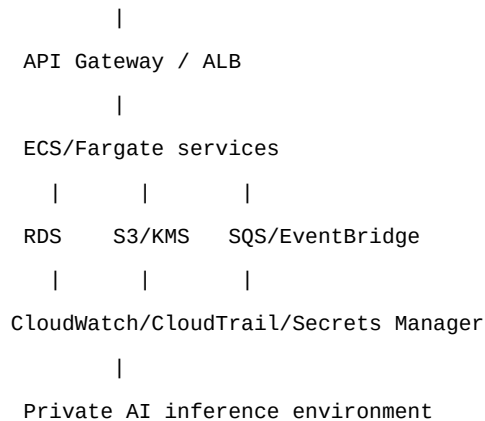
Cloud target: AWS-compatible healthcare deployment architecture

25.2 Initial service boundaries

- api - core domain/application API
- media-service or media module - storage, derivatives, access tokens
- ai-gateway - internal AI job API and model routing
- image-processing - thumbnails, normalization, registration, artifact jobs
- notifications - APNs/email/SMS integrations without sensitive payloads
- integration-service - FHIR/vendor adapters
- worker - queues, exports, sync, derivative generation

25.3 AWS-oriented deployment map

CloudFront/WAF (admin/public static assets only)



Only services included in the organization's applicable agreements and configured appropriately may handle regulated data. Public CDN caching of patient media is prohibited.

25.4 Scale planning

Scale	Architecture posture
~10 practices	Single production region, multi-AZ DB, containerized API/workers, encrypted object storage, modest autoscaling
~100 practices	Read/write capacity monitoring, worker scaling, stronger queue partitioning, search/index strategy, observability/SLOs
~1,000 practices	Horizontal API/worker scaling, database performance engineering/partitioning strategy, tenant-aware rate limits, dedicated AI capacity planning, disaster-recovery exercises

26. Observability, Operations & Support

- Structured application logs with strict PHI filtering.
- Metrics for API latency/error rate, queue depth, upload success, AI job duration/failure, integration health.
- Distributed tracing using safe identifiers.
- Security event alerts.
- Synthetic health checks that do not use real patient data.
- Operational dashboards by environment.
- Runbooks for authentication outage, storage outage, AI outage, integration outage, suspected data exposure, and failed deployment.
- Feature flags for controlled rollout; flags never bypass authorization.

27. Testing & Acceptance Strategy

27.1 Test layers

- Unit tests
- Domain/state-machine tests
- API contract tests
- Database/migration tests
- Authorization tests
- Tenant-isolation tests
- Media permission tests
- iOS ViewModel/domain tests
- UI automation for critical flows
- Integration-adapter tests
- AI regression/identity-preservation tests
- Security tests
- Performance/load tests on critical endpoints
- Backup/restore and disaster-recovery tests before enterprise rollout

27.2 Feature definition of done

1. Functional requirements implemented.
2. Acceptance criteria satisfied.
3. Authorization implemented server-side.
4. Validation implemented.
5. Audit events implemented where required.
6. Loading, empty, error, permission-denied, and offline states implemented where applicable.
7. Database migrations created and tested.
8. Tests added and passing.
9. Documentation and API contracts updated.
10. Architecture decisions recorded when material.
11. No hidden placeholder implementation remains in the feature.

28. Environments, CI/CD & Release Management

28.1 Environments

LOCAL -> DEV -> STAGING -> PRODUCTION

Production data is never copied into lower environments without an approved de-identification process.

28.2 CI gates

- Formatting/linting
- Type checking
- Unit/API/database tests
- Migration validation
- Dependency/security scanning
- Container scanning
- Terraform validation/plan review
- iOS build and tests
- No deployment when required gates fail

28.3 Deployment

Use versioned, repeatable deployments. Database migrations are forward-planned and reversible where feasible. AI model deployments are independent, versioned, and support rollback.

29. Build Layers & Development Roadmap

Layer	Scope	Exit condition
Layer 0 - Architecture Foundation	Monorepo plan, architecture docs, DB design, API conventions, security model, design system, IaC skeleton, ADRs	Architecture pack accepted; repo can be initialized reproducibly
Layer 1 - Identity, Tenancy, Patients	Auth, organizations, practices, locations, users, permissions, patient CRUD/search, audit, provider app shell	Cross-tenant tests pass; iOS login/patients work
Layer 2 - Photography Core	Protocols, photo sessions, camera, upload, immutable originals, derivatives, permissions	Standard photo session works end-to-end
Layer 3 - Consultations & Before/After	Consultation lifecycle, annotations, before/after, timeline	Consultation with standardized imagery is functional
Layer 4 - Documents, Consent, Education, Treatment Plans	Versioned docs/consents/content, plans/estimates	Patient-facing plan/document workflow is testable
Layer 5 - Patient App & Messaging	Patient auth, released content, secure messaging, notifications	Patient can securely access assigned/released records
Layer 6 - Telehealth & Scheduling	Appointments, telehealth integration/workflow	Scheduled virtual consultation lifecycle works
Layer 7 - AI Infrastructure	AI gateway, model registry, quality, landmarks, segmentation, validation harness	Versioned AI jobs with provenance
Layer 8 - Outcome Simulation	Procedure-specific visualization engines, provider review/release	Initial validated simulation categories
Layer 9 - Similar Cases & Outcome Analysis	Historical case search and measured comparisons	Permission-safe similar-case workflow
Layer 10 - Integrations	FHIR/vendor adapters, sync monitoring	Selected partner integrations stable
Layer 11 - 3D Digital Patient	Depth/multi-view model and 3D visualization	Separate approved product expansion

30. Claude Development Constitution

The following block should be supplied to Claude together with this PDF or its extracted text at the start of every substantial development session.

ROLE:

You are the principal engineering agent for a production commercial healthcare software platform.

AUTHORITY:

The Software Production Bible is the source of truth.

Precedence:

1. Software Production Bible
2. ARCHITECTURE_DECISIONS.md
3. DATABASE_SCHEMA.md
4. API_CONTRACTS.md
5. SECURITY_REQUIREMENTS.md
6. DESIGN_SYSTEM.md
7. Current approved layer specification

RULES:

- Do not copy proprietary vendor code, graphics, trade dress, content, or private APIs.
- Do not invent locked product behavior.
- Do not build UI that bypasses backend authorization, persistence, audit, validation, or tests.
- Enforce tenancy server-side.
- Never destructively edit original clinical photos.
- Never infer marketing, research, or AI-training permission from clinical consent.
- Never expose provider drafts or rejected AI simulations to patients.
- Never describe simulations as guaranteed or exact outcomes.
- Never implement automatic dosing, diagnosis, or treatment recommendation unless a future approved specification explicitly authorizes it.
- Never put PHI in logs, analytics, crash reports, or push payloads.
- Use explicit state machines where defined.
- Implement only the authorized layer.
- At layer completion, run tests, perform acceptance review, summarize files/migrations/APIs/security/limitations, and STOP.

IMPLEMENTATION OUTPUT:

For each created or changed file, show:

FILE: relative/path

then the complete file content unless a patch is explicitly requested.

NO PLACEHOLDERS:

Do not replace required implementation with:

TODO

implementation goes here

existing code

...

unless that capability is explicitly deferred by the active layer.

31. Exact Claude Kickoff Prompt - Layer 0

Use this prompt first. Layer 0 is intentionally architecture-first so Claude does not begin with disconnected mock screens.

You have been given SOFTWARE_PRODUCTION_BIBLE_v1.0.

AUTHORIZED LAYER:

LAYER 0 - ARCHITECTURE FOUNDATION

Do not implement Layer 1 business features yet.

FIRST, read the entire Production Bible and create the architecture baseline.

DELIVERABLES:

1. SYSTEM_ARCHITECTURE.md
2. ARCHITECTURE_DECISIONS.md
3. REPOSITORY_STRUCTURE.md
4. DATABASE_SCHEMA.md
5. Initial Prisma schema
6. API_CONTRACTS.md
7. AUTHENTICATION_ARCHITECTURE.md
8. AUTHORIZATION_RBAC.md
9. PHOTO_ARCHITECTURE.md
10. AI_ARCHITECTURE.md
11. SECURITY_REQUIREMENTS.md
12. THREAT_MODEL.md
13. IOS_ARCHITECTURE.md
14. DESIGN_SYSTEM.md
15. TESTING_STRATEGY.md
16. DEPLOYMENT.md
17. INFRASTRUCTURE.md
18. ACCEPTANCE_CRITERIA.md
19. CHANGELOG.md
20. Monorepo/repository skeleton with no fake business implementation.

REPOSITORY TARGET:

/apps

 /ios-provider

 /ios-patient

 /admin-web

/services

 /api

```

    /ai-gateway
    /image-processing
    /notifications
    /integration-service
/packages
    /api-contracts
    /database
    /security
    /design-tokens
    /shared-types
/infrastructure
    /terraform
/docs

```

ARCHITECTURE REQUIREMENTS:

- Multi-tenant organization/practice/location model.
- Server-side permission authorization.
- PostgreSQL + migrations.
- Immutable original photo architecture.
- Secure object storage and signed access.
- Versioned APIs.
- AI services isolated behind authenticated internal APIs.
- Audit/event architecture.
- Offline-safe iOS architecture.
- IaC.
- Clear separation between DTOs and persistence models.

INITIALIZATION COMMANDS:

Provide exact commands for the selected toolchain and explain prerequisites.

Default preferences:

- Node.js current supported LTS
- pnpm workspaces
- TypeScript
- NestJS
- PostgreSQL
- Prisma
- Terraform
- Swift 6 / SwiftUI
- Swift Package Manager
- Xcode project/workspace generation using a reproducible method

BEFORE CREATING FILES:

Report:

- A. assumptions
- B. unresolved decisions
- C. final architecture choices
- D. files to create
- E. risks

THEN create the Layer 0 files.

ACCEPTANCE REVIEW:

For each Layer 0 deliverable print PASS / FAIL / DEFERRED BY SPECIFICATION.

STOP after Layer 0.

Do not begin Layer 1.

32. Exact Claude Prompt - Layer 1

BEGIN LAYER 1

Read:

SOFTWARE_PRODUCTION_BIBLE

ARCHITECTURE_DECISIONS.md

DATABASE_SCHEMA.md

API_CONTRACTS.md

SECURITY_REQUIREMENTS.md

DESIGN_SYSTEM.md

IOS_ARCHITECTURE.md

TESTING_STRATEGY.md

AUTHORIZED SCOPE:

- Authentication/session foundation
- Organizations
- Practices
- Locations
- Users
- Roles
- Permissions
- User-role assignments
- Tenant enforcement
- Provider profiles
- Patient create/read/update/archive
- Patient search
- Patient profile shell
- Audit foundation
- Provider iOS shell
- Swift API client
- Secure Keychain/session service
- Error model
- Navigation foundation
- Automated tests

DO NOT IMPLEMENT:

Photography business workflows

Consultation business workflows

AI simulations

Consents

Messaging

Telehealth

Patient application business functionality

unless a minimal interface is required by the approved architecture.

INITIAL PERMISSIONS:

patient.read

patient.create

patient.update

patient.archive

user.read

user.create

user.update

user.disable

role.read

role.assign

practice.read

practice.manage

audit.read

REQUIRED AUDIT EVENTS:

LOGIN_SUCCESS

LOGIN_FAILURE

LOGOUT

PATIENT_CREATED

PATIENT_VIEWED

PATIENT_UPDATED

PATIENT_ARCHIVED

USER_CREATED

USER_UPDATED

USER_DISABLED

ROLE_ASSIGNED

LAYER 1 ACCEPTANCE:

1. Local database starts.
2. Migrations execute.
3. Seed creates an organization and admin.
4. Admin can authenticate.
5. Authorized staff can create patient.
6. Authorized provider can open allowed patient.
7. Cross-tenant access is rejected server-side.
8. Patient search works.
9. Patient profile shell opens.

10. Audit events are written.
11. Provider iOS app builds.
12. Login UI works.
13. Patient list/search/create work.
14. Required tests pass.
15. Run/test/migration commands are documented.

OUTPUT:

Implement file-by-file with complete relative paths.

Update architecture/API/database/security docs as needed.

At completion list:

- features
- new files
- modified files
- migrations
- APIs
- permissions
- audit events
- tests
- security considerations
- known limitations
- exact run/test commands
- acceptance review

Then STOP.

33. Feature Prompt Template for All Later Layers

FEATURE NAME:

PURPOSE:

What problem does the feature solve?

AUTHORIZED USERS:

Roles and, more importantly, explicit permissions.

DATA:

Entities read, created, updated, archived, or exported.

STATE MACHINE:

Every valid state and transition.

WORKFLOW:

Exact step-by-step sequence.

API:

Endpoints, DTOs, idempotency, pagination/filtering where relevant.

UI:

Screens, navigation, loading, empty, error, offline, permission-denied states.

SECURITY:

Tenant rules, sensitive-data rules, media rules, re-authentication where needed.

AUDIT:

Exact events generated.

FAILURE BEHAVIOR:

Validation, network, authorization, storage, AI/integration failures.

ACCEPTANCE CRITERIA:

Numbered, objectively testable conditions.

TESTS:

Unit, API, database, authorization, tenant isolation, UI/integration/AI as applicable.

IMPLEMENTATION BOUNDARY:

Explicitly list what is not part of this feature/layer.

STOP CONDITION:

Complete this feature/layer, run acceptance review, then stop.

34. Representative Acceptance Criteria

34.1 Before/After

12. Provider can select exactly two images belonging to the same patient.
13. Server rejects image IDs from another tenant or patient.
14. Original assets remain untouched.
15. Side-by-side, slider, cross-fade, blink, and overlay modes function.
16. Zoom and pan can be synchronized.
17. Automatic registration can be disabled/reset.
18. Export verifies purpose-specific permission.
19. Export creates PHOTO_EXPORTED.
20. Invalid/unauthorized images do not reveal cross-tenant existence.
21. Tests cover successful flow, invalid IDs, permission denial, and export failure.

34.2 AI simulation

22. Only authorized users can create/generate simulations.
23. Every generation references source assets and model/version.
24. Unsupported/poor-quality inputs fail with safe actionable status.
25. Outside-region identity validation is executed according to the model specification.
26. Patient cannot see READY_FOR_PROVIDER_REVIEW, REJECTED, or FAILED outputs.
27. Only authorized provider can approve.
28. Release is a separate explicit action after approval.
29. Patient-facing release includes disclaimer.
30. All lifecycle events are audited.
31. No dosage, product, drug, technique, or guaranteed-outcome recommendation is generated by the initial feature.

35. Target Repository & Documentation Pack

```
/
apps/
  ios-provider/
  ios-patient/
  admin-web/
services/
  api/
  ai-gateway/
  image-processing/
  notifications/
  integration-service/
packages/
  api-contracts/
  database/
  security/
  design-tokens/
  shared-types/
infrastructure/
  terraform/
docs/
  SOFTWARE_PRODUCTION_BIBLE.md
  ARCHITECTURE_DECISIONS.md
  PRODUCT_REQUIREMENTS.md
  USER_ROLES_AND_PERMISSIONS.md
  WORKFLOWS.md
  DATABASE_SCHEMA.md
  API_CONTRACTS.md
  SECURITY_REQUIREMENTS.md
  THREAT_MODEL.md
  AI_ARCHITECTURE.md
  AI_SIMULATION_RULES.md
  PHOTO_ARCHITECTURE.md
  PHOTO_PROTOCOLS.md
  CONSENT_ARCHITECTURE.md
  EMR_INTEGRATIONS.md
  DESIGN_SYSTEM.md
  IOS_ARCHITECTURE.md
  TESTING_STRATEGY.md
  DEPLOYMENT.md
  INFRASTRUCTURE.md
```

ACCEPTANCE_CRITERIA.md

CHANGELOG.md

36. Production Readiness Checklist

Area	Must be true before production
Tenancy	Automated cross-tenant tests pass for every sensitive domain
Authentication	Session expiration/revocation tested; secrets stored securely
Authorization	Server-side permission checks cover sensitive endpoints
Photos	Originals immutable; permissions enforced; private storage only
AI	Versioned provenance; provider review/release; regression validation
Consents	Versioned templates; immutable signed snapshot/hash; audit
Messaging	No sensitive push payload; attachment controls enforced
Audit	Critical events captured and queryable
Logging	PHI filtering verified
Backups	Encrypted backup and tested restore
CI/CD	Security/test gates mandatory
Monitoring	Operational and security alerting configured
Legal/compliance	BAAs/contracts/policies/retention/intended-use reviewed for actual deployment

36.1 Final instruction to Claude

Do not optimize for how much code can be generated in one session. Optimize for architectural consistency, traceability, security, and acceptance-tested increments. The Production Bible wins whenever an implementation shortcut conflicts with it.

Appendix A - Canonical State & Event Reference

Object	Canonical states
Consultation	DRAFT, IN_PROGRESS, AWAITING_INFORMATION, READY_FOR_REVIEW, COMPLETED, CANCELLED, ARCHIVED
Simulation	DRAFT, QUEUED, PROCESSING, VALIDATING, READY_FOR_PROVIDER_REVIEW, APPROVED, REJECTED, REGENERATING, RELEASED_TO_PATIENT, ARCHIVED, FAILED
Treatment Plan	DRAFT, PROPOSED, SENT_TO_PATIENT, VIEWED, ACCEPTED, DECLINED, EXPIRED, SCHEDULED, COMPLETED, CANCELLED
Consent	DRAFT, ASSIGNED, VIEWED, IN_PROGRESS, SIGNED_BY_PATIENT, SIGNED_BY_PROVIDER, COMPLETE, VOIDED, SUPERSEDED
Photo Permission	NOT_REQUESTED, REQUESTED, GRANTED, DECLINED, REVOKED, EXPIRED
Appointment	REQUESTED, CONFIRMED, CHECKED_IN, IN_PROGRESS, COMPLETED, CANCELLED, NO_SHOW
Message	DRAFT, SENT, DELIVERED, READ, FAILED
Telehealth	SCHEDULED, WAITING, ACTIVE, DISCONNECTED, ENDED, CANCELLED
Integration Sync	PENDING, RUNNING, SUCCEEDED, PARTIAL, FAILED, RETRY_SCHEDULED

Appendix B - First Session Handoff Checklist

32. Attach or provide this Production Bible to Claude.
33. Paste the Claude Development Constitution from Section 30.
34. Paste the Layer 0 kickoff prompt from Section 31.
35. Require Claude to identify unresolved decisions before locking architecture.
36. Require the complete Layer 0 documentation pack and repository skeleton.
37. Review the acceptance table. Do not allow Claude to proceed automatically.
38. Only after Layer 0 is accepted, send the Layer 1 prompt from Section 32.
39. From Layer 2 onward, use the feature-prompt template in Section 33 and the specific workflows in this Bible.
40. Keep ARCHITECTURE_DECISIONS.md and CHANGELOG.md current after every material decision.
41. Never bypass the phase/layer boundary simply because the coding model can generate more code.